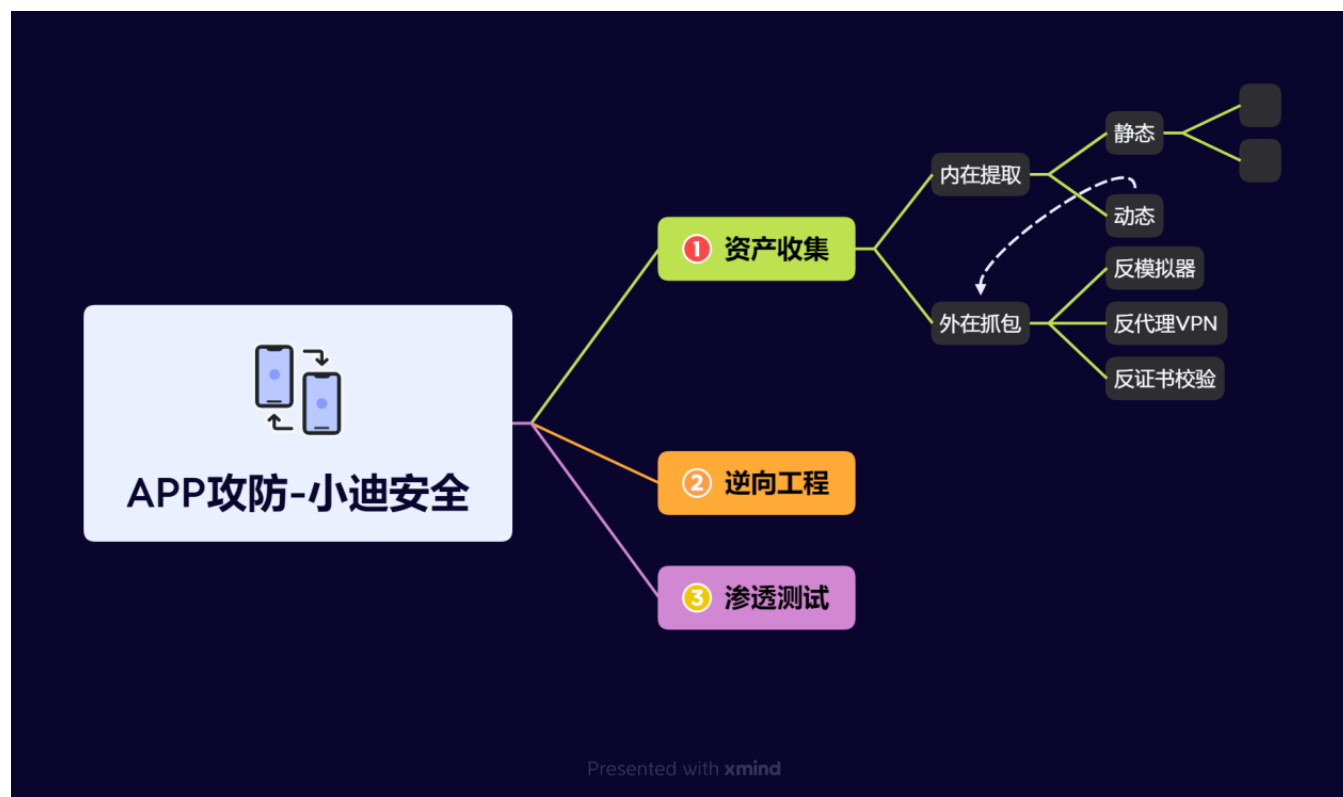


Day86 APP攻防-资产收集篇

&Frida&HOOK&Xposed&证书提取&单向双向&检验抓包

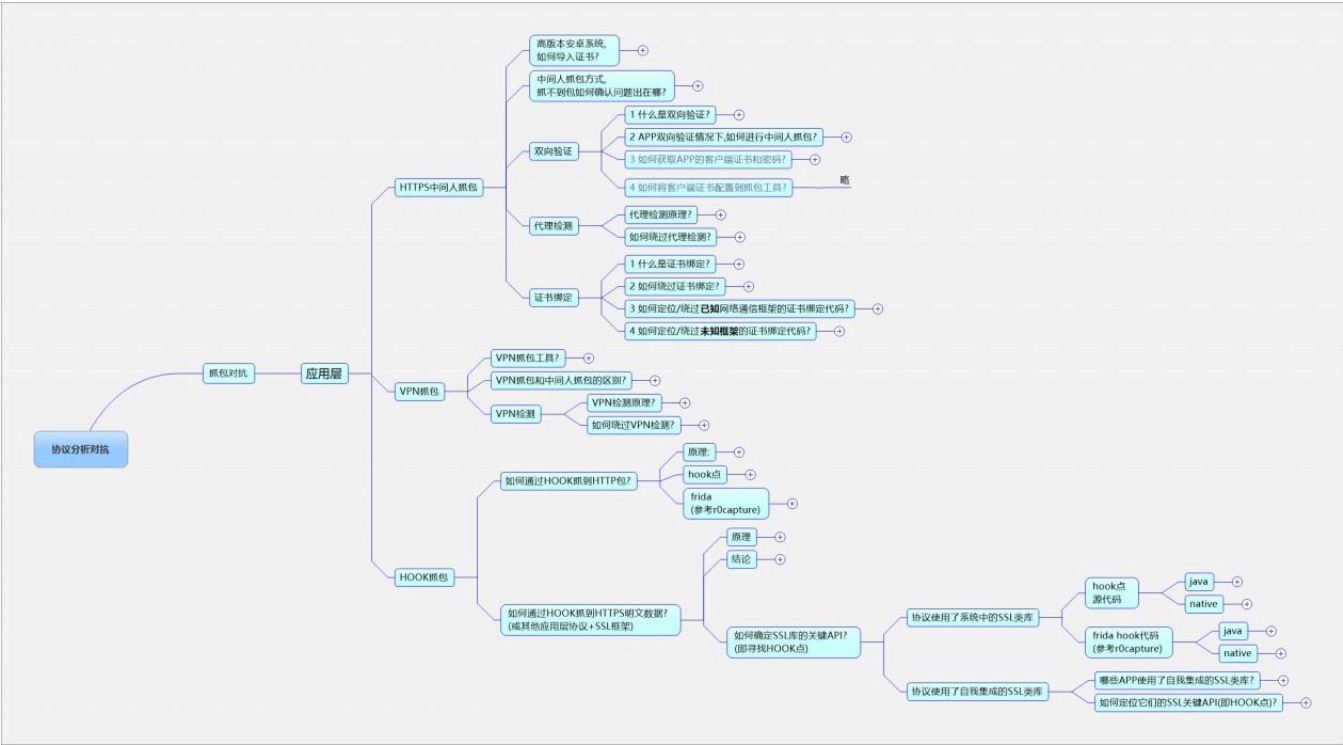


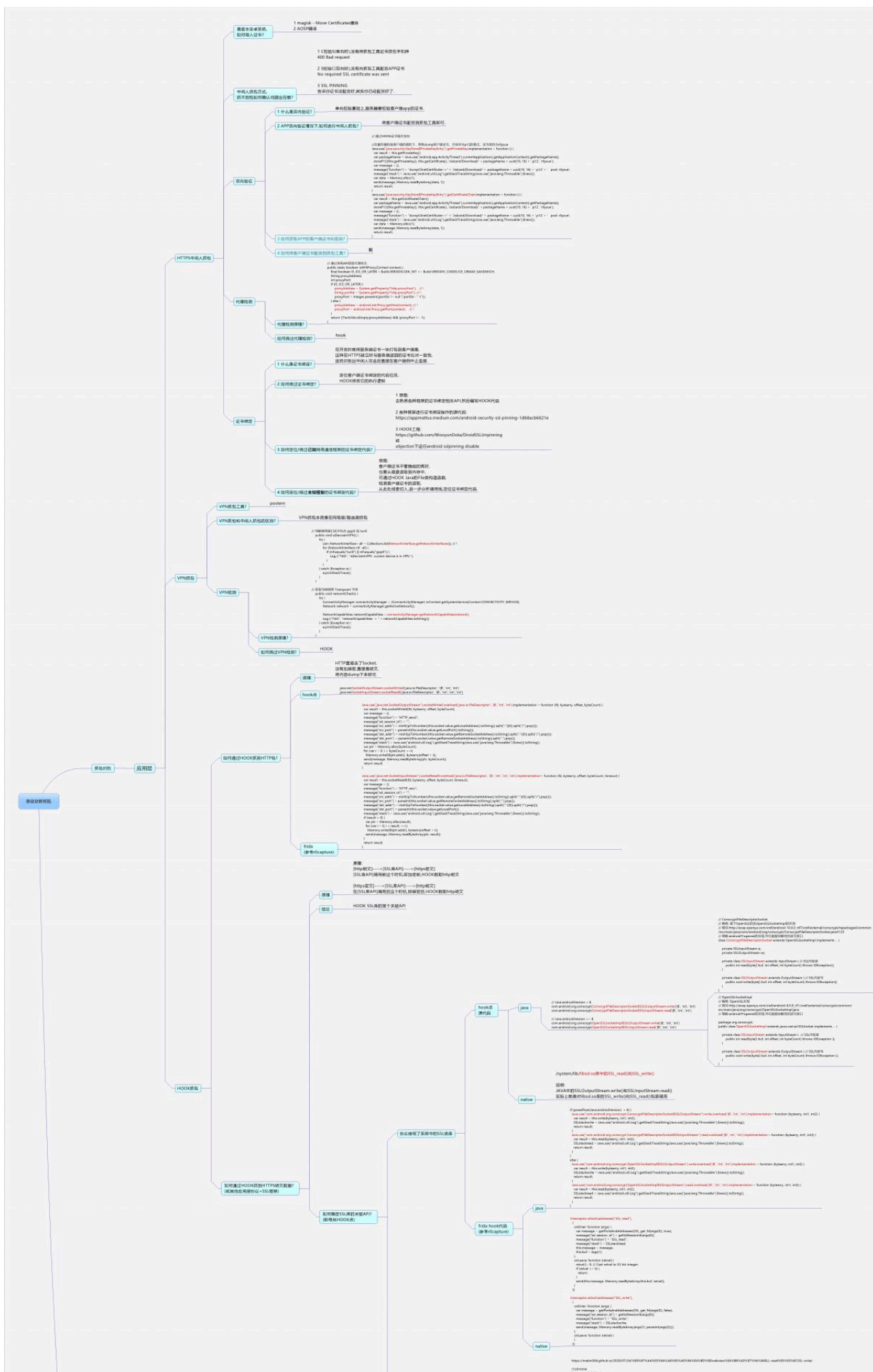
1.知识点

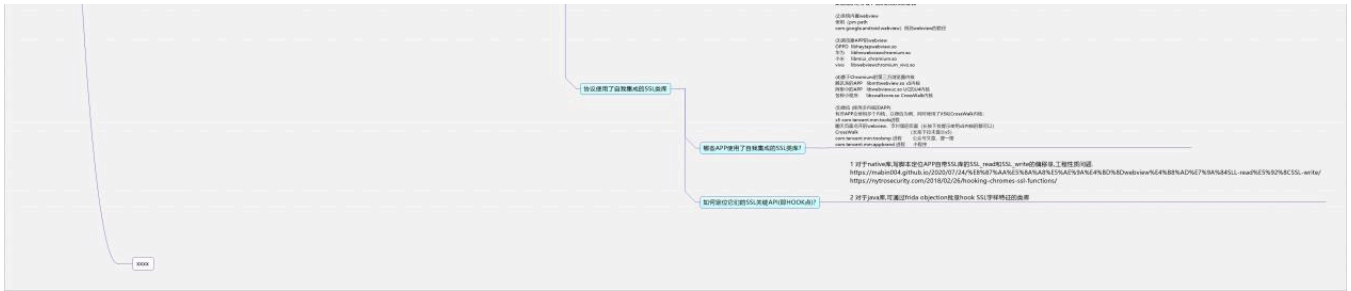
- 1、APP资产-抓包突破&反模拟器
- 2、APP资产-抓包突破&反证书检验
- 3、APP资产-抓包突破&反代理VPN

-
- 1、单向校验-XP框架&Frida&HOOK
 - 2、双向校验-Frida&HOOK&导入证书
 - 3、单项双向-逆向删除反代码重打包
-

2.演示案例







2.1 APP-综合分析-Mobexler&MobSF识别



- 1 -移动安全框架（MobSF）是一种自动化的一体化移动应用程序（Android/iOS/windows）渗透测试、恶意软件分析和安全评估框架，能够执行静态和动态分析。MobSF 支持移动应用程序二进制文件（APK、XAPK、IPA 和 APPX）以及压缩源代码，并提供 REST API 以与您的 CI/CD 或 DevSecOps 管道无缝集成。动态分析器可帮助您执行运行时安全评估和交互式仪器测试。
- 2
- 3 -Mobexler是基于Elementary OS的定制虚拟机，旨在帮助进行Android和iOS应用程序的渗透测试。Mobexler预装了各种开源工具，脚本，黑客必备软件等，这些都是安全测试Android和iOS应用程序所必需的。
- 4 <https://mobexler.com/>

2.2 APP-某社交-双向证书绕过&Frida&HOOK



- 1 -r0capture仅限安卓平台，测试安卓7、8、9、10、11可用；无视所有证书校验或绑定，不用考虑任何证书的事情；通杀TCP/IP四层模型中的应用层中的全部协议；通杀协议包括：Http,WebSocket,Ftp,Xmpp,Imap,Smtp,Protobuf等、及它们的SSL版本；通杀所有应用层框架，包括URLConnection、Okhttp1/3/4、Retrofit/Volley等等；无视加固，不管是整体壳还是二代壳或VMP，不考虑加固事情
- 2
- 3 -Frida 是一款易用的跨平台Hook工具，Java层到Native层的Hook无所不能，是一种 动态 的插桩工具，可以插入代码到原生App的内存空间中，动态的去监视和修改行为，原生平台包括Win、Mac、Linux、Android、iOS全平台。



- 1 测试环境：
- 2 Python3 夜神模拟器 r0capture frida-server Burpsuite Wireshark
- 3 <https://github.com/frida/frida/releases>
- 4 1、本地安装Frida
- 5 `pip install frida`
- 6 `pip install frida-tools`
- 7 2、模拟器安装Frida
- 8 注意：版本要与本地Frida一致
- 9 下载：<https://github.com/frida/frida/releases>
- 10 真机：ARM版本及位数 模拟器：无ARM的位数
- 11 `getprop ro.product.cpu.abi`
- 12 `adb push frida-server /data/local`
- 13 `cd /data/local/tmp/`
- 14 `chmod 777 frida-server`
- 15 `./frida-server`
- 16 `ps | grep frida`

```
17 3、转发并启动Frida
18 adb forward tcp:27042 tcp:27042
19 连接判断: frida-ps -U frida-ps -R
```

```
1 方案1: Firda+r0capture+Wireshark
2 https://github.com/r0ysue/r0capture
3 模拟器执行: ./frida-server
4 获取包名: ls /data/data 或 Apk资源器查看
5 python r0capture.py -U -f 包名 -p xxxx.pcap
6
7 方案2: Firda+HOOK-JS+BurpSuite
8 https://github.com/apkunpacker/FridaScripts
9 模拟器执行: ./frida-server
10 本地执行: frida -U -f 包名 -l hookjs文件
11
12 方案3: 导入证书
13 利用场景: 能反编译, 有证书文件
14 1、解压获取apk的证书文件
15 2、反编译后得到证书文件的密钥
16 3、Burp导入证书后实现对应抓包
17
18 IOS端-双向认证-SSL kill switch 2
19 教程地址: https://testerhome.com/topics/17249
20 GitHub: https://github.com/nabla-c0d3/ssl-kill-switch2/releases
```

2.3 APP-某游戏-单向证书绕过&XP框架&Frida

```
1 方案1: Xposed+SSL模块+BurpSuite
2 逍遥模拟器安装xp已经上节课讲过
3 夜神模拟器安装xp直接市场下载后激活即可
4
5 方案2: Firda+HOOK-JS+BurpSuite
6 模拟器执行: ./frida-server
7 本地执行: frida -U -f 包名 -l hookjs文件
```